

PCI DSS



Shweta A. Chawla
Founder & Investigator
SC Cyber Solutions

PCI DSS



- ❶ Payment Car Industry Data Security Standard
- ❷ Developed due to increase in identity theft, credit card fraud
- ❸ Set of security standards **formed in 2004** by Visa, MasterCard, Discover Financial Services, JCB International and American Express
- ❹ Has a set of requirements for credit card and debit card transactions and account data security
- ❺ Latest version – v4.0 – released March 2022



- ❶ Governed by the Payment Card Industry Security Standards Council (PCI SSC)
- ❷ PCI SSC has no legal authority to compel compliance
- ❸ It is a requirement for any business that processes credit or debit card transactions

Who has to comply



- 🦨 Merchants
- 🦨 Service providers



Compliance Levels

- ❶ PCI compliance is divided into four levels, based on the annual number of credit or debit card transactions a business processes





🦊 Level 1

- 🦊 Internal audit conducted by an authorised PCI auditor annually
- 🦊 Quarterly PCI scan by an Approved Scanning Vendor (ASV)

🦊 Level 2

- 🦊 Complete an assessment once a year using a Self-Assessment Questionnaire (SAQ)
- 🦊 Quarterly PCI scan by an Approved Scanning Vendor (ASV) might be needed



🔴 Level 3

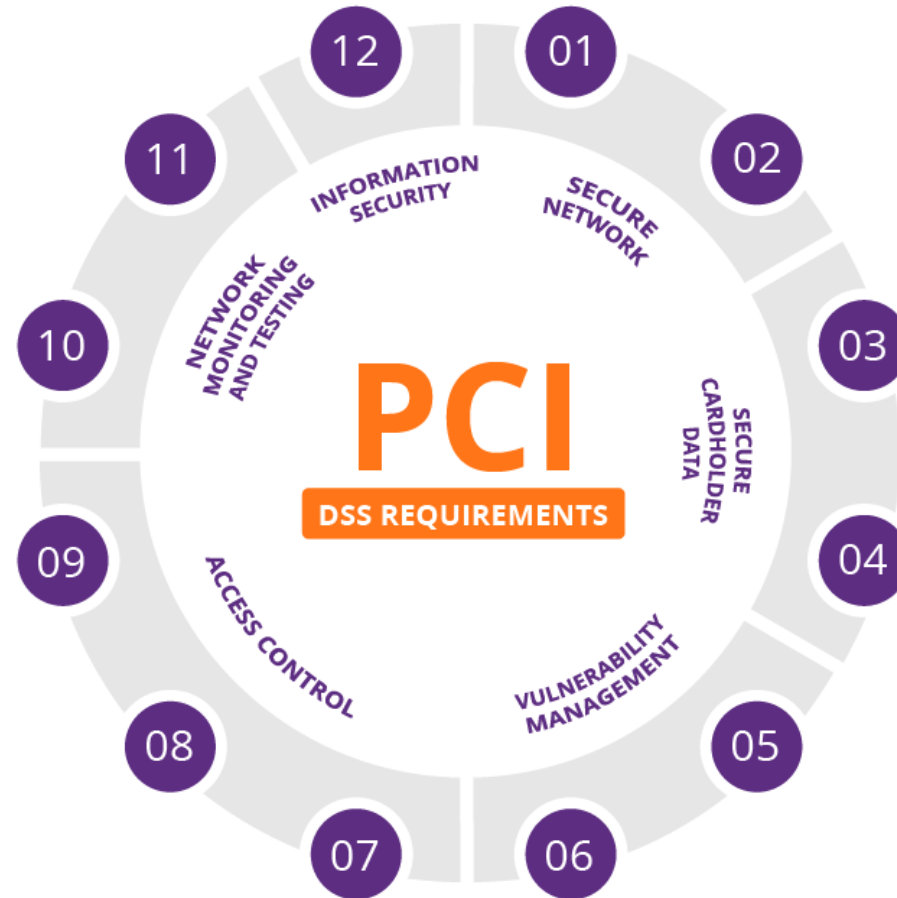
- ✔ Complete an assessment once a year using a Self-Assessment Questionnaire (SAQ)
- ✔ Quarterly PCI scan by an Approved Scanning Vendor (ASV) might be needed

🔴 Level 4

- ✔ Complete an assessment once a year using a Self-Assessment Questionnaire (SAQ)
- ✔ Quarterly PCI scan by an Approved Scanning Vendor (ASV) might be needed



Requirements





- ❶ Secure network
 - ❧ A firewall configuration must be installed and maintained
 - ❧ System passwords must be original (not vendor-supplied)
- ❷ Secure cardholder data
 - ❧ Stored cardholder data must be protected
 - ❧ Transmissions of cardholder data across public networks must be encrypted
- ❸ Vulnerability management
 - ❧ Anti-virus software must be used and regularly updated
 - ❧ Secure systems and applications must be developed and maintained



- ❶ Access control
 - ❧ Cardholder data access must be restricted to a business need-to-know basis
 - ❧ Every person with computer access must be assigned a unique ID
 - ❧ Physical access to cardholder data must be restricted
- ❷ Network monitoring and testing
 - ❧ Access to cardholder data and network resources must be tracked and monitored
 - ❧ Security systems and processes must be regularly tested
- ❸ Information security
 - ❧ A policy dealing with information security must be maintained

Thank You!

Contact details:

Mob: +91 98230 80864

shweta@sccybersolutions.com

www.sccybersolutions.com

[@sccs1300](#)

